Czy 25 milionów USD to dużo? Ile jest warte konto uprzywilejowane?

Michał Siemieniuk – COMTEGRA
Łukasz Kajdan – VERACOMP

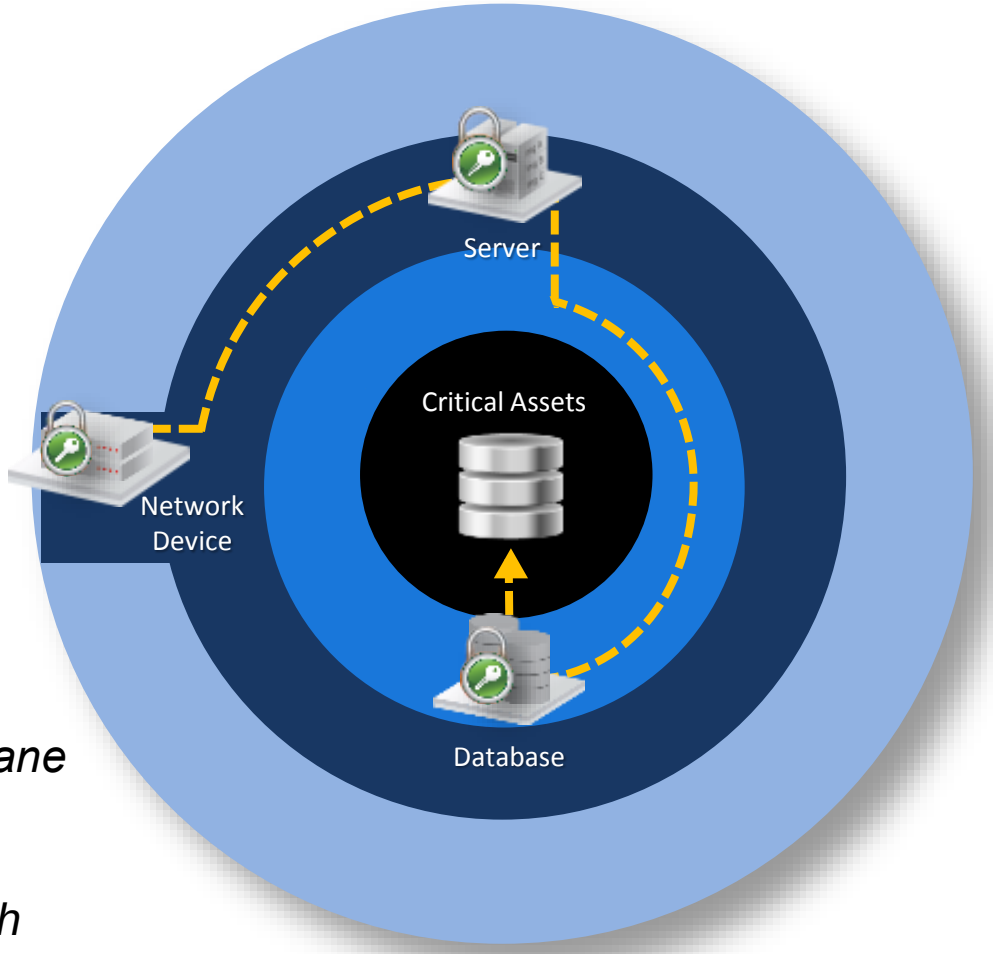
Agenda

- Anunak /Carbanak - analiza ataku
- Jak wyglądają hasła i dlaczego
- Wyzwania stojące za uwierzytelnianiem login/hasłami
- Zarządzanie kontami uprzywilejowanymi
- Architektura CyberArk
- Podsumowanie

Wszystkie zaawansowane ataki celują w konta uprzywilejowane

"…100% włamań używało skradzionych danych logowania"."

Konta uprzywilejowane
Jedyny sposób na dostęp do danych



"Hakerzy, wykorzystują konta uprzywilejowane tam, gdzie jest to tylko możliwe. Konta Administratorów domeny, konta usług z uprawnieniami do domeny, kont lokalnych administratorów i uprzywilejowanych użytkowników"

Mandiant, M-Trends and APT1 Report

CYBERARK

Hasła i poziom ich skomplikowania

Hasła

Lp.	Zestaw znaków	Liczba znaków w zbiorze	Hasło 8 znaków		Hasło 16 znaków	
			Kombinacje	Entropia	Kombinacje	Entropia
1.	Cyfry (4 znakowy PIN)	10	10000	13,28		
2.	Litery bez rozróżnienia na duże i małe	26	$2*10^{11}$	37,54	$4*10^{22}$	75,08
3.	Małe i duże litery	52	$5*10^{13}$	45,50	$3*10^{27}$	91,27
4.	Małe duże litery i cyfry	62	$2*10^{14}$	47,50	$5*10^{28}$	95,33
5.	Małe duże litery, cyfry symble	95	$7*10^{15}$	52,63	$4*10^{31}$	104,98

Człowiek jest słabym RNG ☺

		Hasło wybierane przez człowieka				Hasło losowe	
		94 znakowy alfabet			10 znakowy alfabet		94 znakowy alfabet
Lp.	Długość hasła	Bez sprawdzania	Metoda słownikowa	Metoda słownikowa rozszerzona			
1.	4	10	14	16	9	13,3	26,3
2.	8	18	24	30	13	16,6	52,7
3.	12	24	28	34	17	40,0	79,0
4.	16	30	32	38	21	53,3	105,4
5.	22	38	38	44	27	73,3	144,7
6.	40	56	56	62	45	133,2	263,4

Jak zarządzać jak blokować ☺

		Poziom entropii				
Lp.	Czas blokady	90 dni	180 dni	1 rok	2 lata	5 lat
1.	1 minuta	33	34	35	36	37
2.	10 minut	29	30	31	32	34
3.	1 godzina	27	28	29	30	31
4.	1 dzień	22	23	24	25	26

Analiza ataku: Anunak/Carbanak

Anunak – podsumowanie ataku

Przegląd Ataku	
Cel ataku	Instytucje finansowe
Atakujący	Anunak cybercrime ring
Motyw	Finansowy
Cel:	Kradzież pieniędzy z banków
Rezultat	>$25M do końca 2H 2014

Co się wydarzyło?

- Anunak przeprowadziła atak celowany na kilka banków
- Zdobyć dostęp do kont uprzywilejowanych
- Transfer pieniędzy na konta zewnętrzne
- Kradzież gotówki bezpośrednio z bankomatów

KrebsonSecurity
In-depth security news and investigation

22 DEC 14 **Gang Hacked ATMs from Inside Banks**

An organized gang of hackers from Russia and Ukraine has broken into internal networks at dozens of financial institutions and installed malicious software that allowed the gang to drain bank ATMs of cash. While none of the victim institutions were in the United States or Western Europe, experts say the stealthy methods used by the attackers in these heists would likely work across a broad range of western banks.

Most cybercrime targets consumers and businesses, stealing account

Elina Shchekina <e.shekina@rbkmoney.com>
Обновленная версия догвоора
Сообщение договор.doc
Внимательно читать
--
Best regards,
Shchekina Elina,
Senior accountant
Tel.: +7 (495) [redacted]
e.shekina@rbkmoney.com

Eastern APT group Anunak steals millions from banks

December 23, 2014 By Pierluigi Paganini

Tło ataku

Anunak? Kto to taki?

- Członkowie zaczynali w Carberp cybercrime ring, kradzież bezpośrednio od klientów banków
- Członkowie Anunak łączą się w celu przeprowadzenia bardziej zaawansowanego i przychodowego ataku
- Anunak atakuje banki, nie ich klientów
- Odpowiedzialni za atak na kilka banków w Rosji i Europie Wschodniej
- Ataki zostały również przeprowadzane organizacje obsługujące płatności online i wielu detalistów

ComputerWeekly.com

CYBER CRIME

Russian hacker group Anunak targets banks and payment systems

A hacker group based in Russia and Ukraine is gaining access to the internal payment systems

months

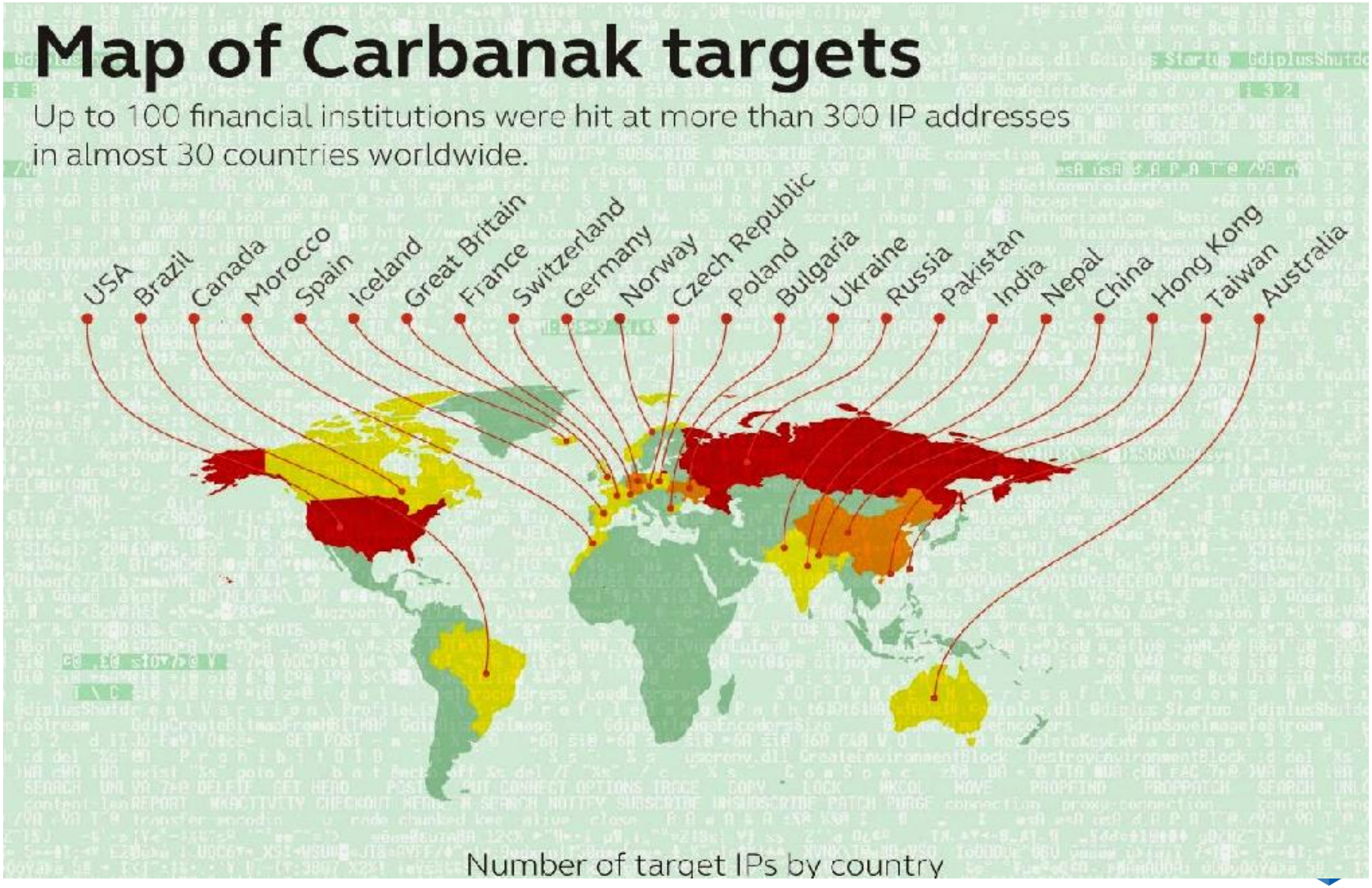
The gro

Fox-IT i

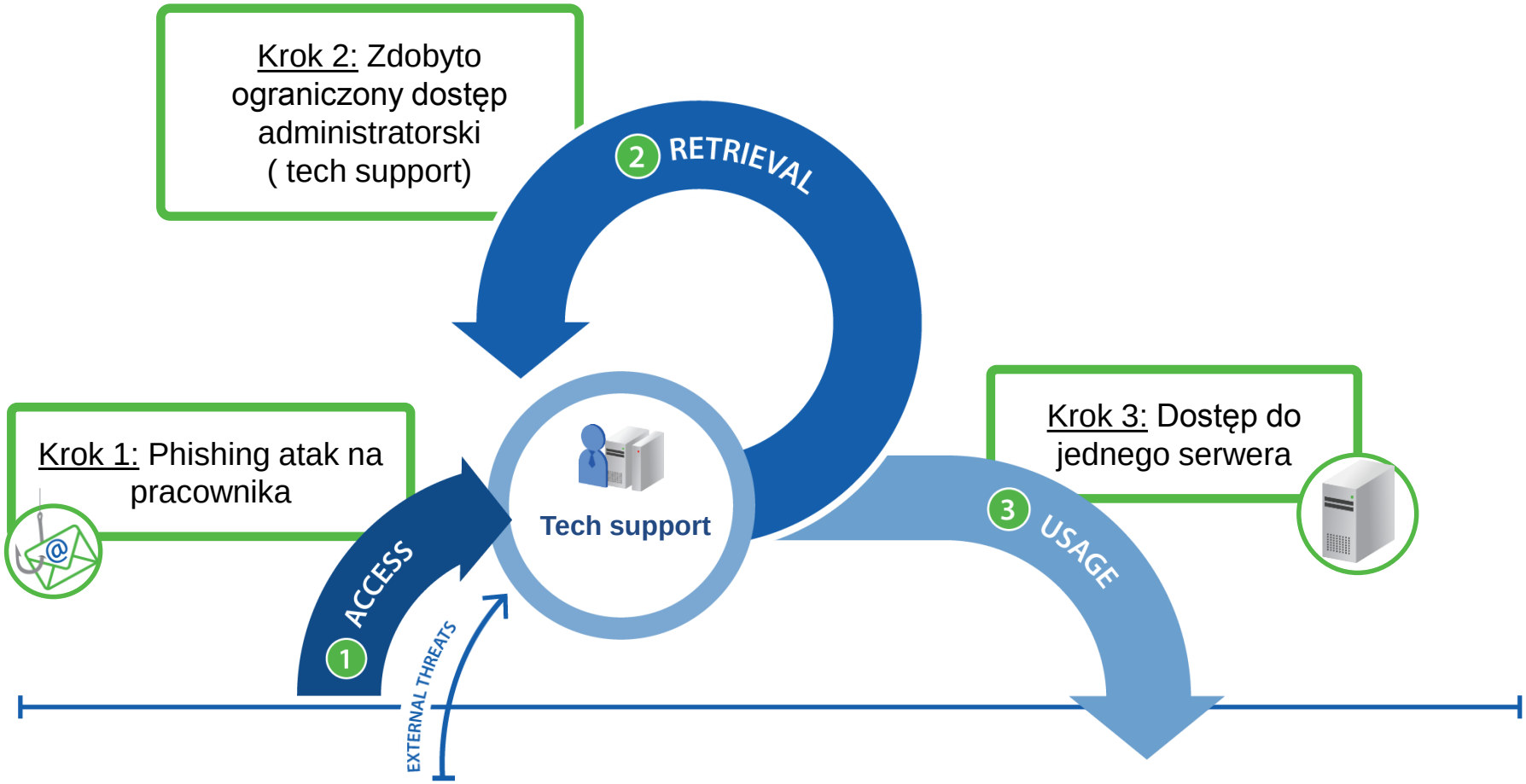
Meet Anunak - The Hacker Crew That Owned Staples And Earned $18m In 2014

In November this year, dignitaries and bigwigs of the cyber security industry gathered inside Europol's headquarters in The Hague. As they talked about general issues affecting the community, namely financially-motivated criminals, ears pricked up when one particular strain of malware, called Anunak, was said to have brought about the "armageddon" of the Russian banking industry, according to Andy Chandler, a senior vice president at security firm Fox-IT.

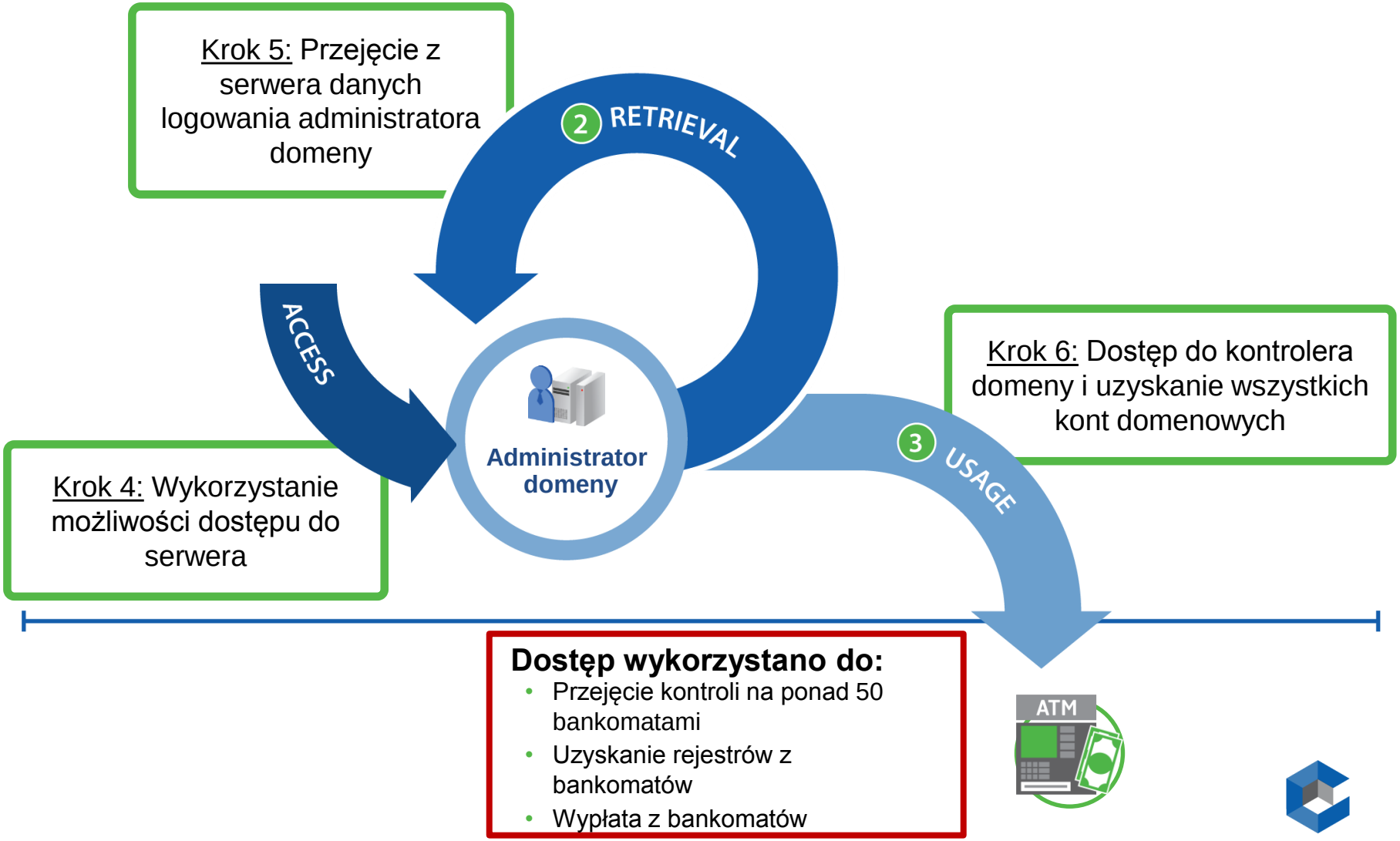
Mapa światowego bogactwa



Od czego się to wszystko zaczęło?



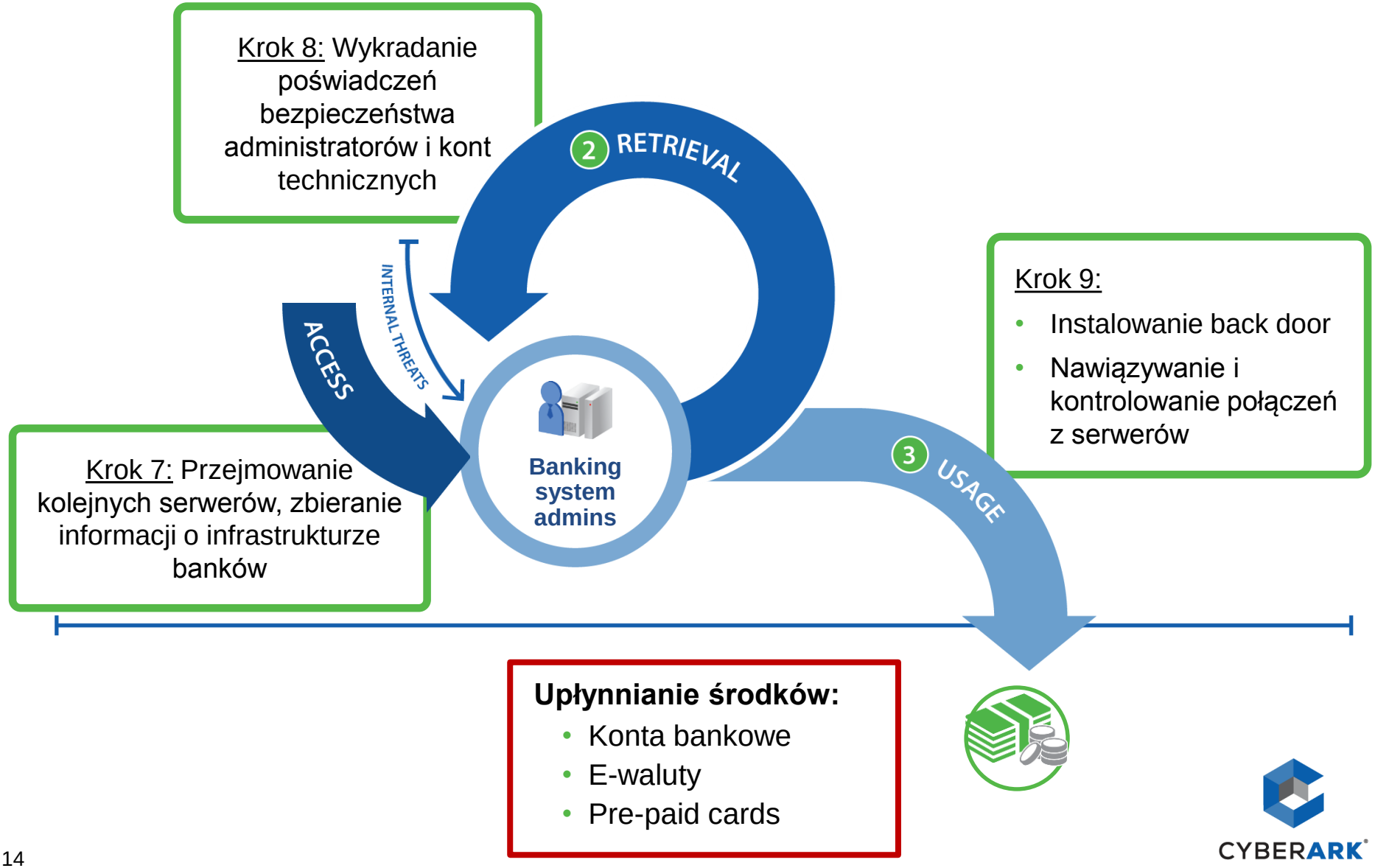
Jak doszło do eskalacji uprawnień?



Dostęp wykorzystano do:

- Przejęcie kontroli na ponad 50 bankomatami
- Uzyskanie rejestrów z bankomatów
- Wypłata z bankomatów

Koniec zabawy?



Rola uprawnień

1

Wykradzenie poświadczeń bezpieczeństwa

2

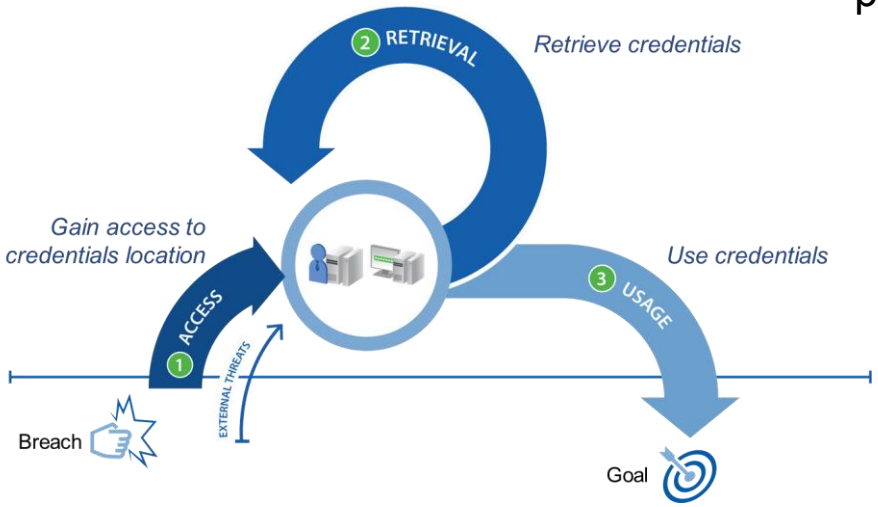
Użycie haseł administratora w celu uzyskania szerokich uprawnień

3

Wykradzenie wysoko uprzywilejowanych kont: AD

4

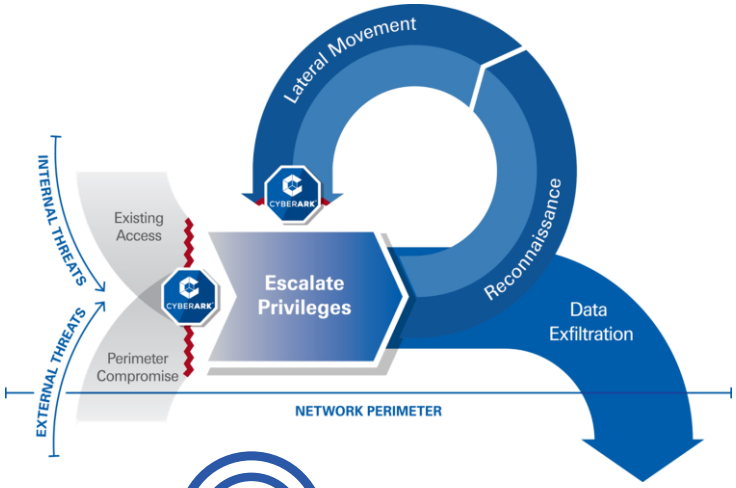
Używnie poświadczeń bezpieczeństwa wykradzionych z AD do swobonej penetracji zasobów



Jak może pomóc CyberArk

Włączenie i umożliwienie zarządzania kontami lokalnymi

Bezpieczne przechowywanie kluczowych poświadczeń bezpieczeństwa



Kontrola dostępu do kluczowych zasobów

Wymuszenie dostępu dla kont uprzywilejowanych w zdefiniowany sposób

Wykrywanie anomalii w posługiwaniu się kontami o podwyższonych uprawnieniach

KEY TAKEAWAY

If there are no domain admin credentials on a local machine, then attackers cannot hijack domain admin credentials from an infected machine.

Konta uprzywilejowane są „kluczem do królestwa informatycznego”

CyberArk to proaktywna ochrona i wykrywanie

CYBERARK

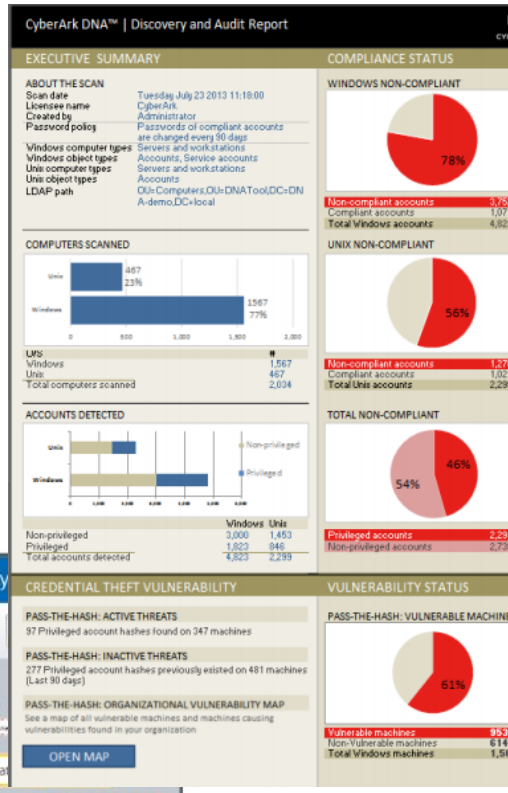
Czym są konta uprzywilejowane i gdzie je odnajdziemy?

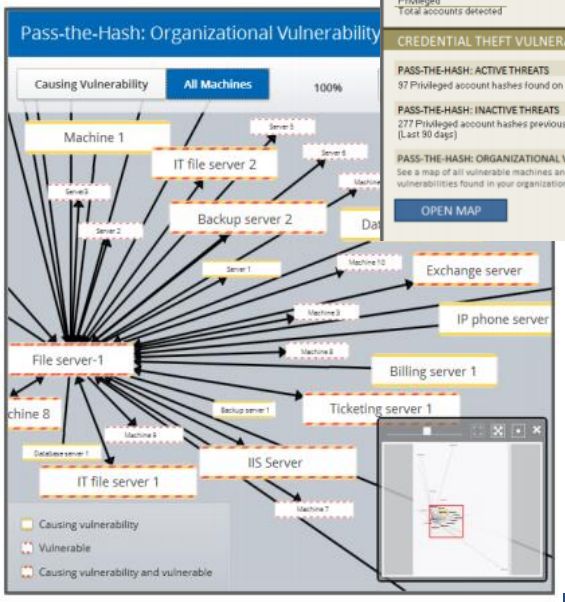
Konta uprzywilejowane w organizacji

- Ile kont posiadasz w organizacji??
- Czy masz nad nimi kontrolę??

CyberArk DNA - Discovery & Audit

- Wykrywa konta uprzywilejowane
- Ułatwia zrozumienie skali zagrożeń
- Uzasadnienie biznesowe:
  - Wskazuje słabe punkty w organizacji
  - Pomaga w planowaniu projektu zabezpieczenia kont uprzywilejowanych





http://www.cyberark.com/discover-where-your-privileged-accounts

Podatność - Pass-the-Hash

CREDENTIAL THEFT VULNERABILITY

PASS-THE-HASH: ACTIVE THREATS

97 Privileged account hashes found on 347 machines

PASS-THE-HASH: INACTIVE THREATS

277 Privileged account hashes previously existed on 481 machines (Last 90 days)

PASS-THE-HASH: MITIGATED WITH PRIVILEGED ACCOUNT SECURITY

Privileged Accounts Security can frequently change Privileged account passwords, turning hashes from Active to Inactive. The data below simulates the use of one-time passwords on all Privileged accounts.

Before: 97 Privileged account hashes on 347 machines
After: 12 Privileged account hashes on 3 machines

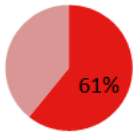
PASS-THE-HASH: ORGANIZATIONAL VULNERABILITY MAP

See a map of all vulnerable machines and machines causing vulnerabilities found in your organization

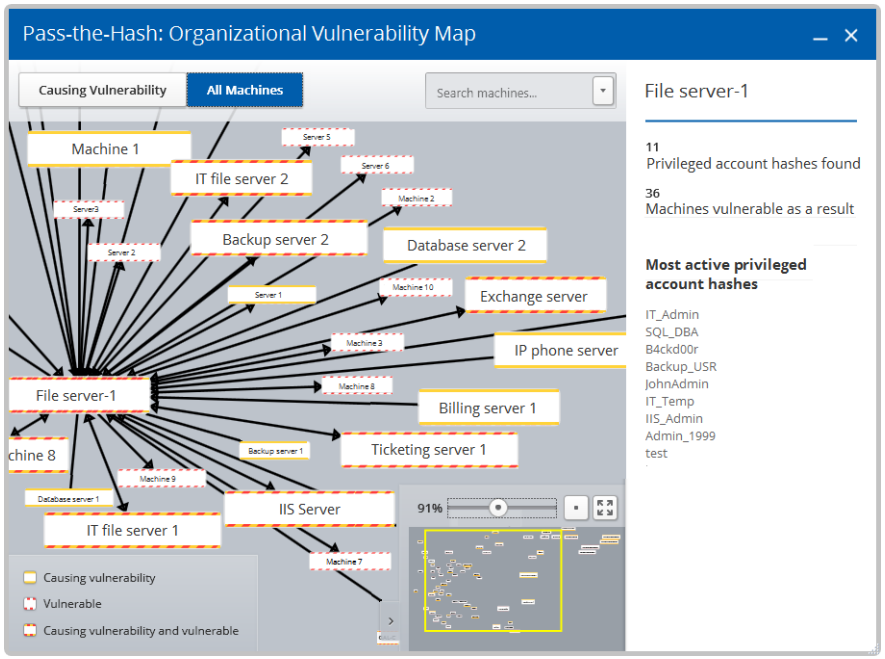
OPEN PTH MAP

VULNERABILITY STATUS

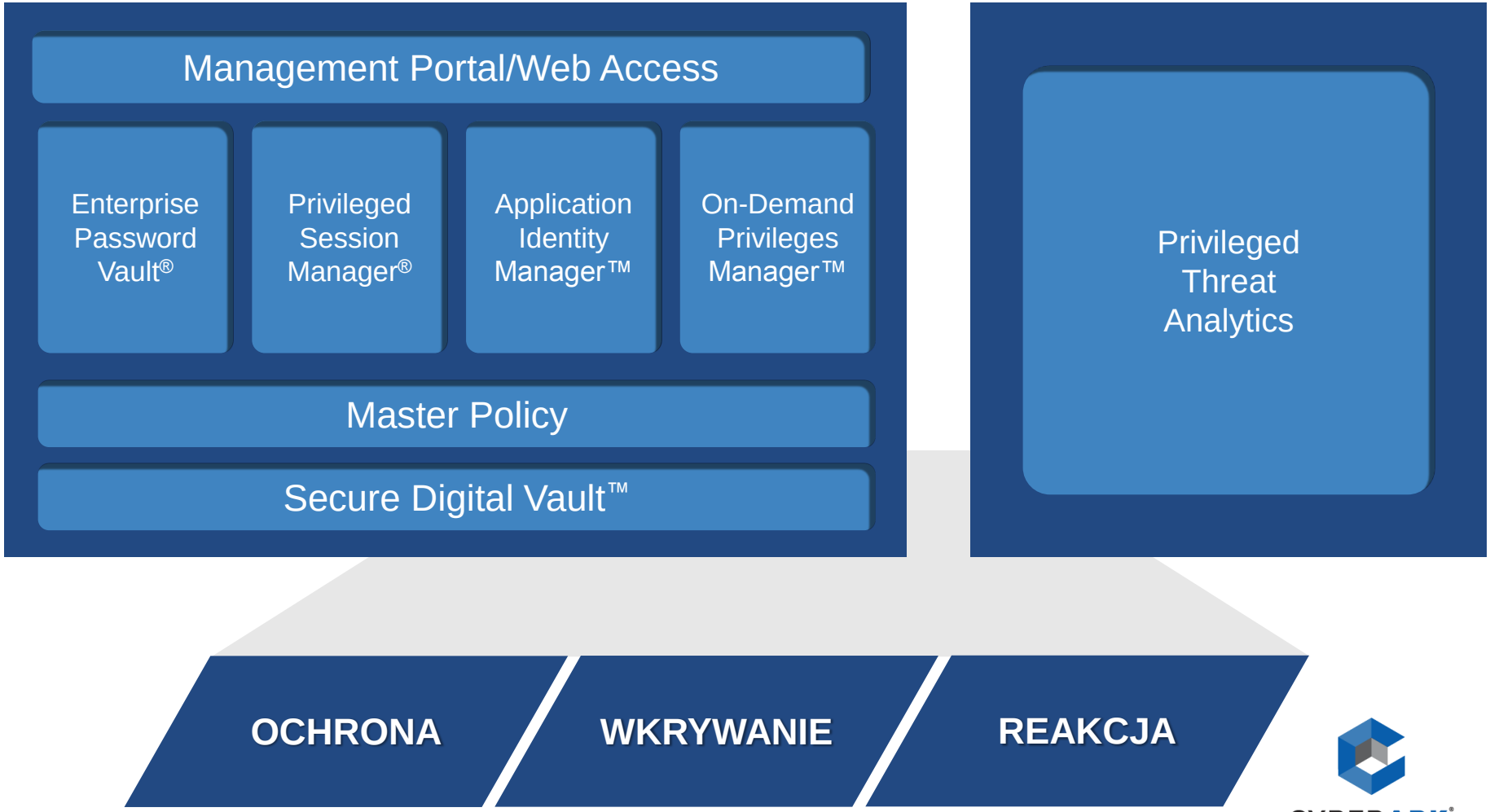
PASS-THE-HASH: VULNERABLE MACHINES



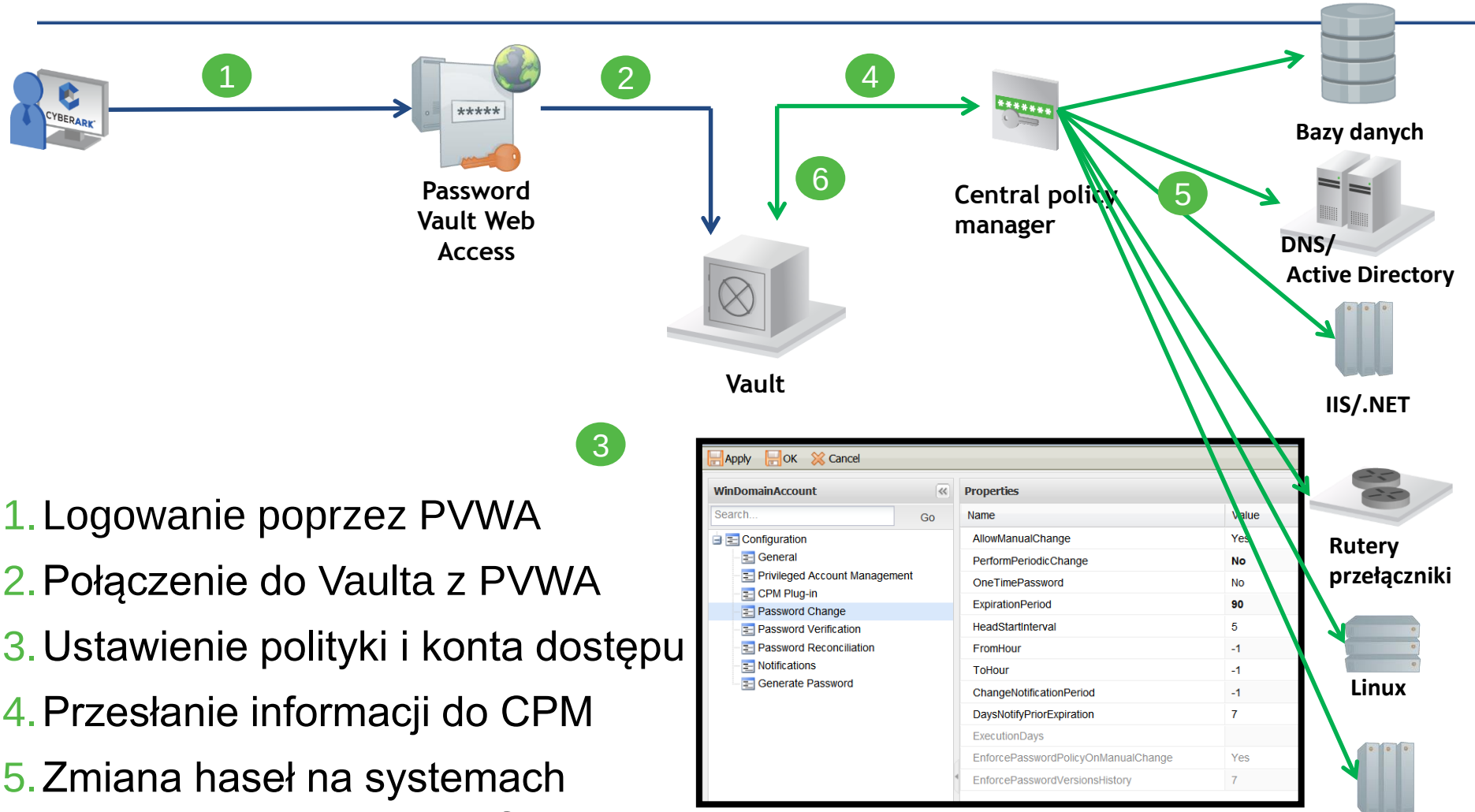
Vulnerable machines	953
Non-Vulnerable machines	614
Total Windows machines	1,567



Rozwiązania CyberArk

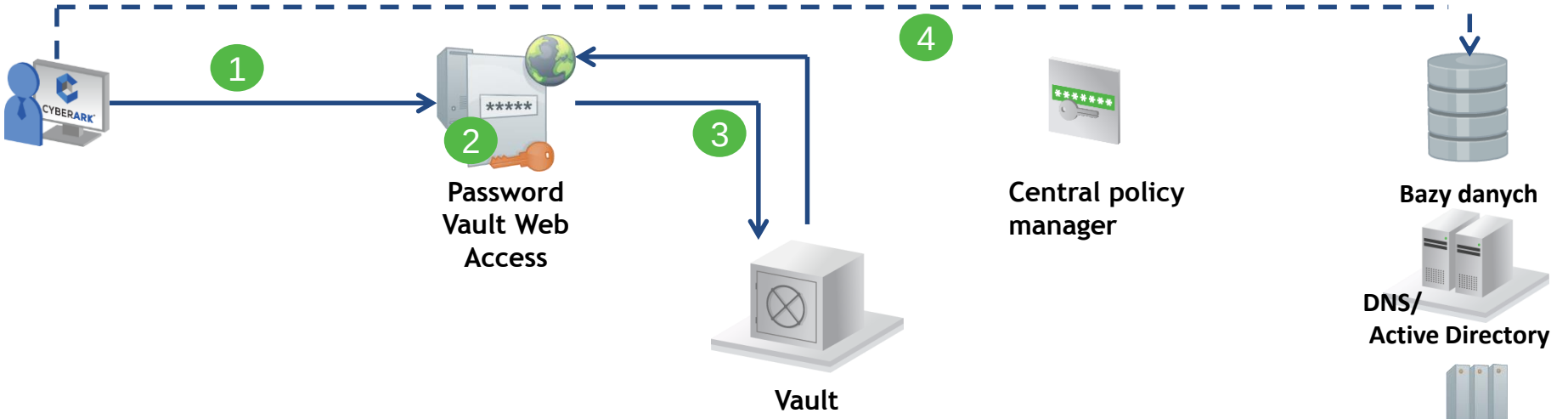


Zarzadzanie hasłami

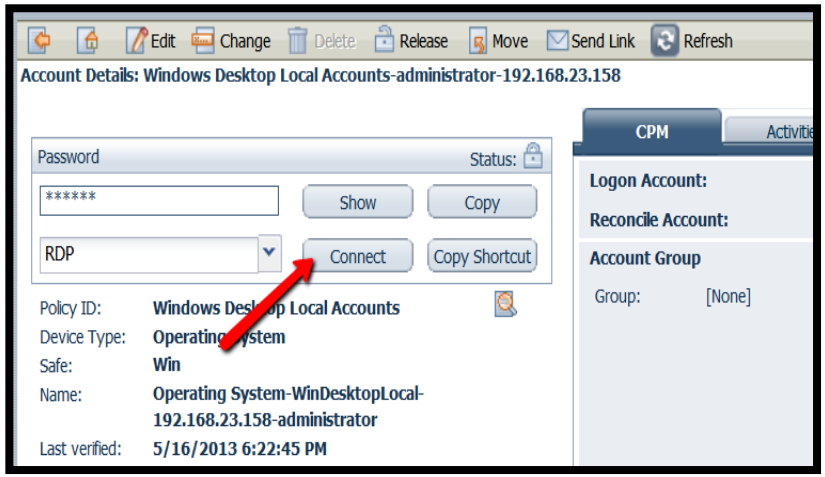


1. Logowanie poprzez PVWA
2. Połączenie do Vaulta z PVWA
3. Ustawienie polityki i konta dostępu
4. Przesłanie informacji do CPM
5. Zmiana haseł na systemach docelowych za pomocą CPM
6. Przesłanie nowych haseł do Vaulta

Dostęp do systemów docelowych



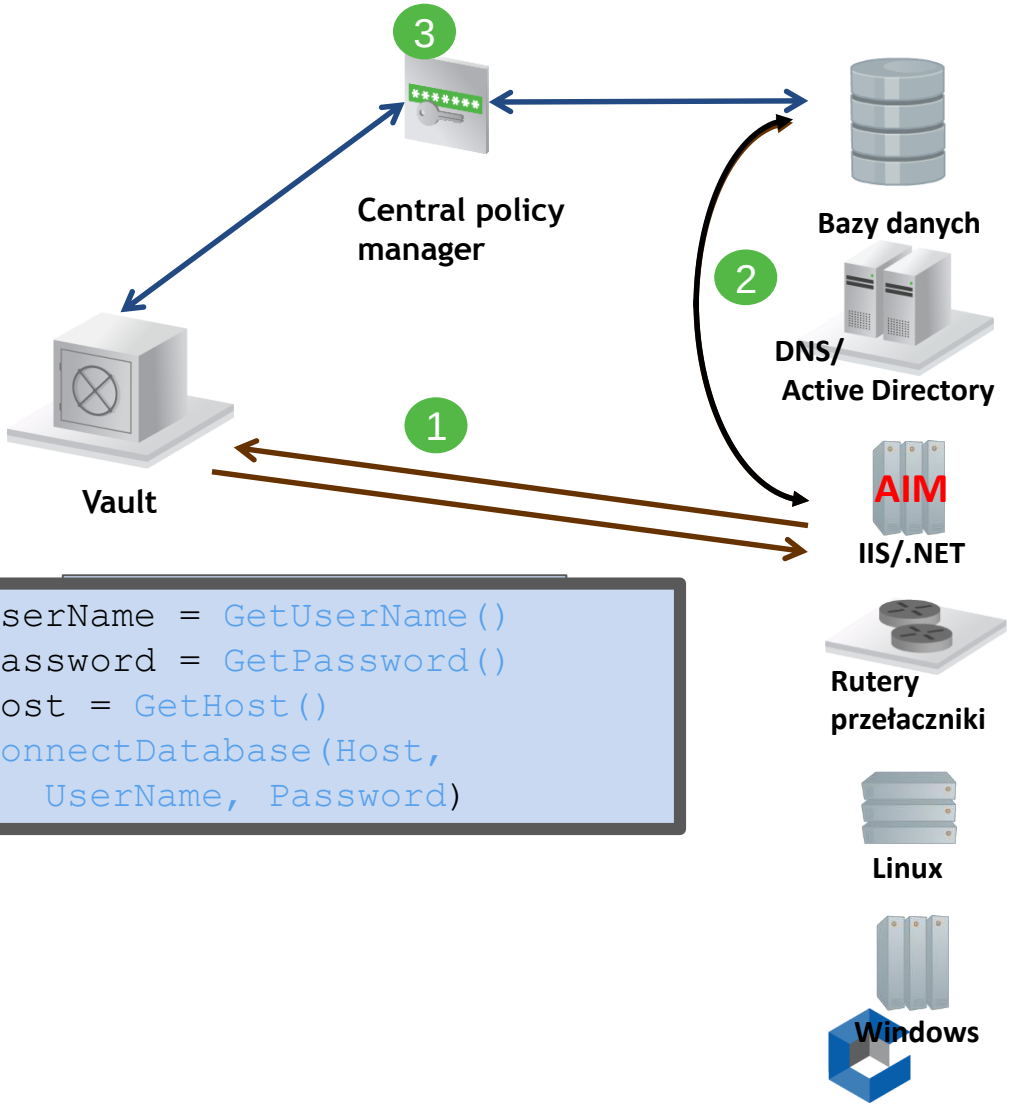
1. Logowanie poprzez PVWA
2. Wybranie odpowiedniego konta
3. Przycisk „Connect” – pobranie hasła logowania z Vaulta
4. Otwarcie sesji z komputera do systemu docelowego



Zarządzanie hasłami dostępu aplikacji

Password Vault Web Access

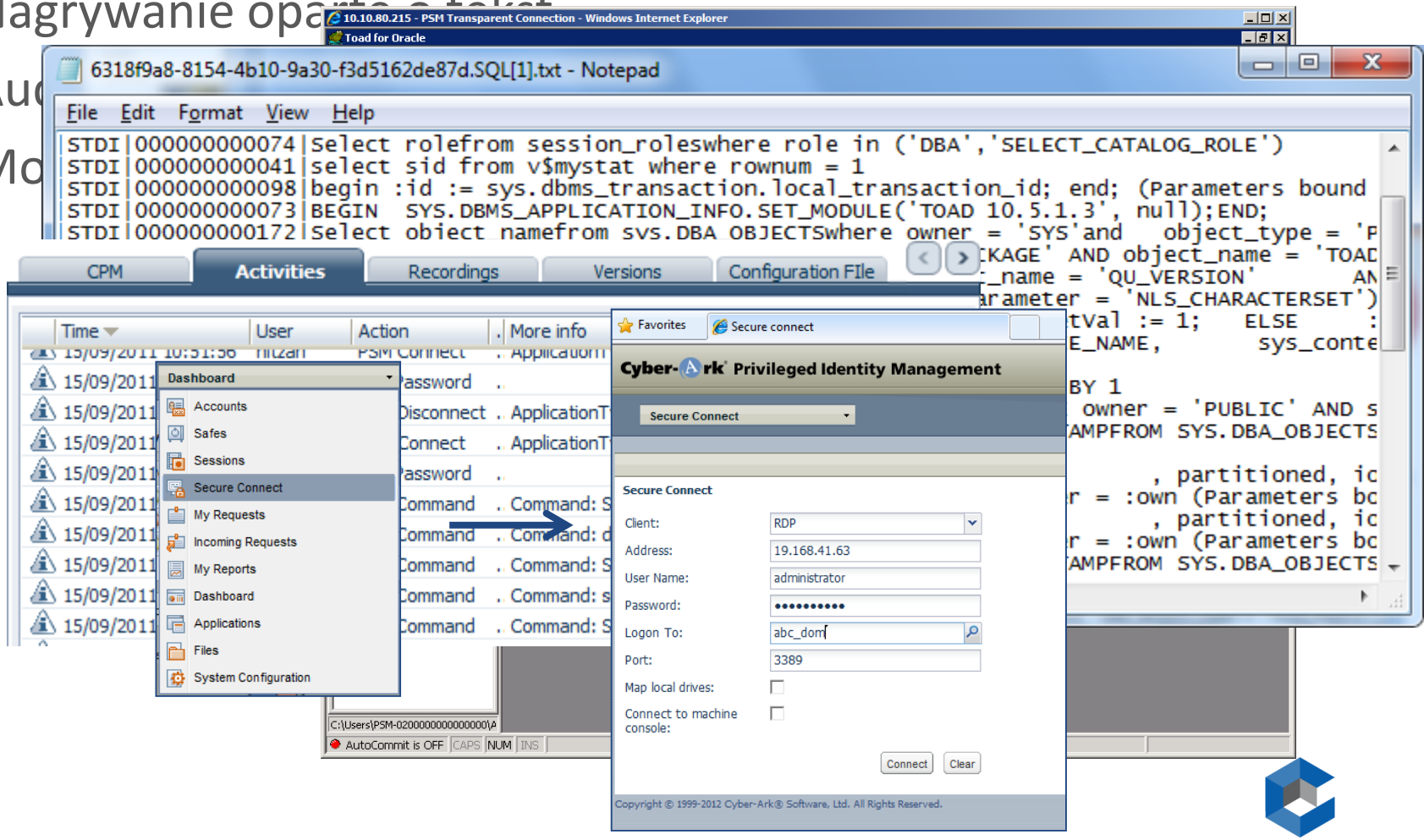
1. Pobranie hasła z Vaulta
2. Użycie hasła do komunikacji z inna aplikacją
3. Zmiana hasła aplikacji zgodnie z polityką bezpieczeństwa




```
UserName = GetUserName()
Password = GetPassword()
Host = GetHost()
ConnectDatabase(Host,
   UserName, Password)
```

Monitorowanie zarządzanych i niezarządzanych kont

- Nagrywanie video
- Nagrywanie oparte o tekst
- Au
- Mo

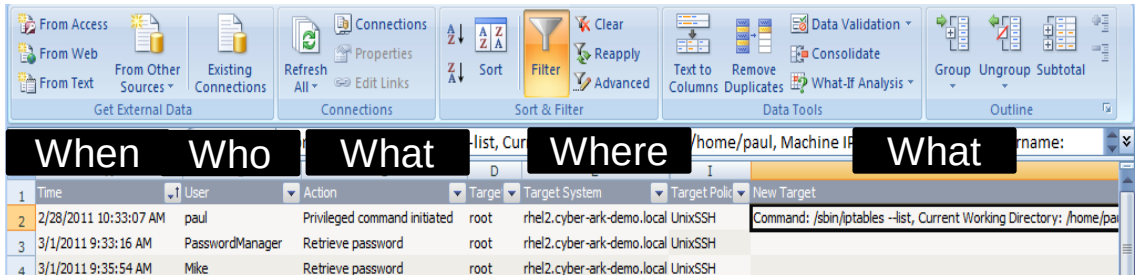


PSM Universal Connector

- Klienci często pytają o większa liczbę wspieranych klientów
  - Niektóre aplikacje są własnością klientów

- PSM Universal Connector (lub Generic Client Support) jest obecnie frameworkiem który pozwala:
  - Łatwo tworzyć skrypt, który automatyzuje proces logowania
  - Zintegrowane w środowisku PSM

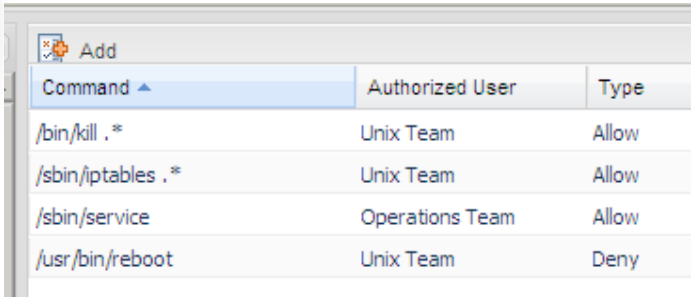
On-Demand Privilege Manager dla Unix i Windows



Monitorowanie i audyt z raportem oraz tekstem

Kontrola dostępu do kont uprzywilejowanych (root, oracle, Administrator…)

Serwery Windows Unix /Linux



Add

Command	Authorized User	Type
/bin/kill .*	Unix Team	Allow
/sbin/iptables .*	Unix Team	Allow
/sbin/service	Operations Team	Allow
/usr/bin/reboot	Unix Team	Deny

Granularna kontrola uprawnień

Jak działa Privileged Threat Analytics ?

Kolekcja

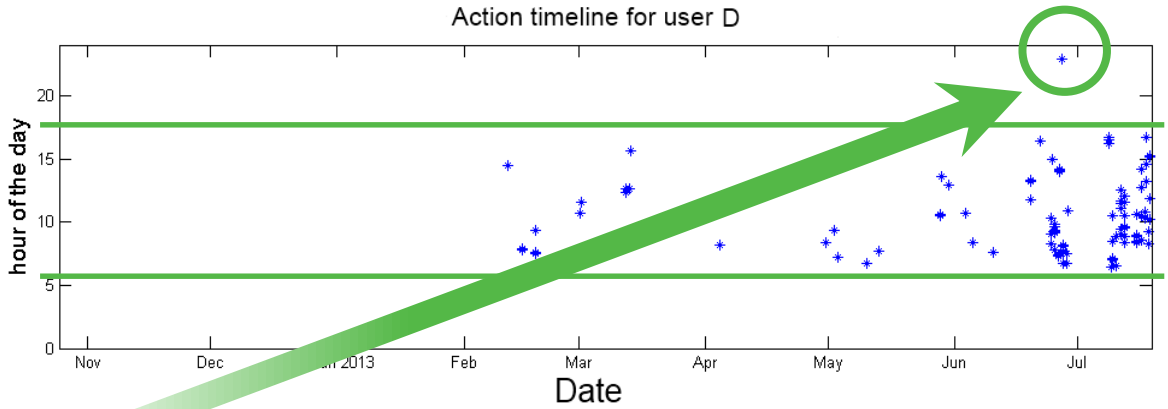
Zbiera aktywność kont uprzywilejowanych

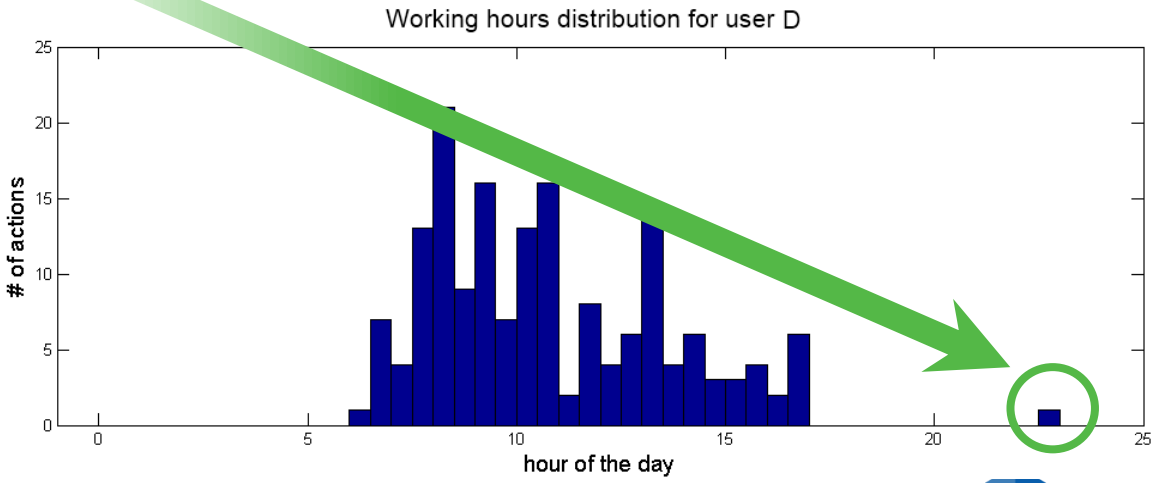
Monitorowanie

Uczenie się wzorców zachowań i dostosowanie ich do działania organizacji

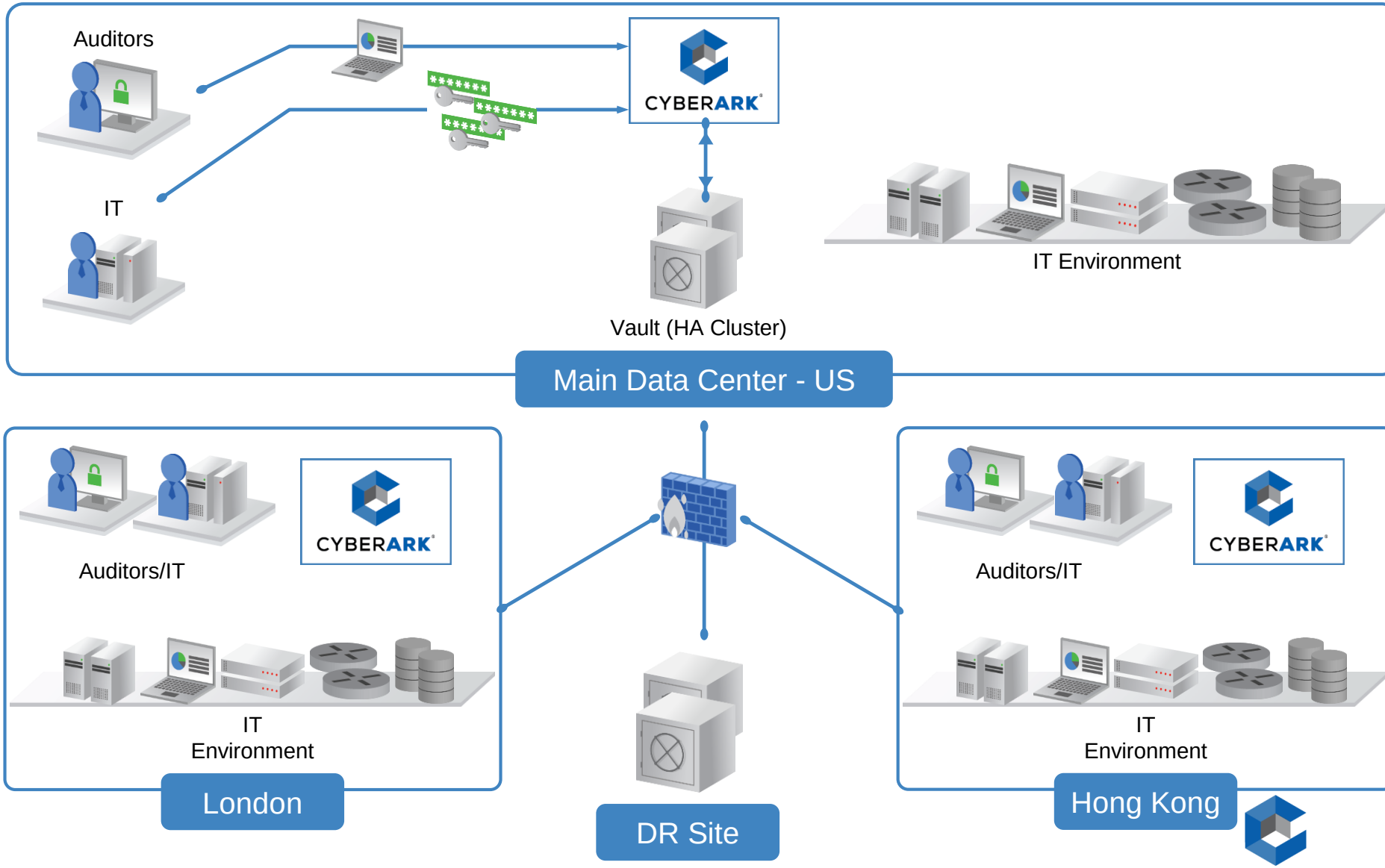
Wykrywanie

Wykrywanie aktywności niestandardowej dla kont uprzywilejowanych

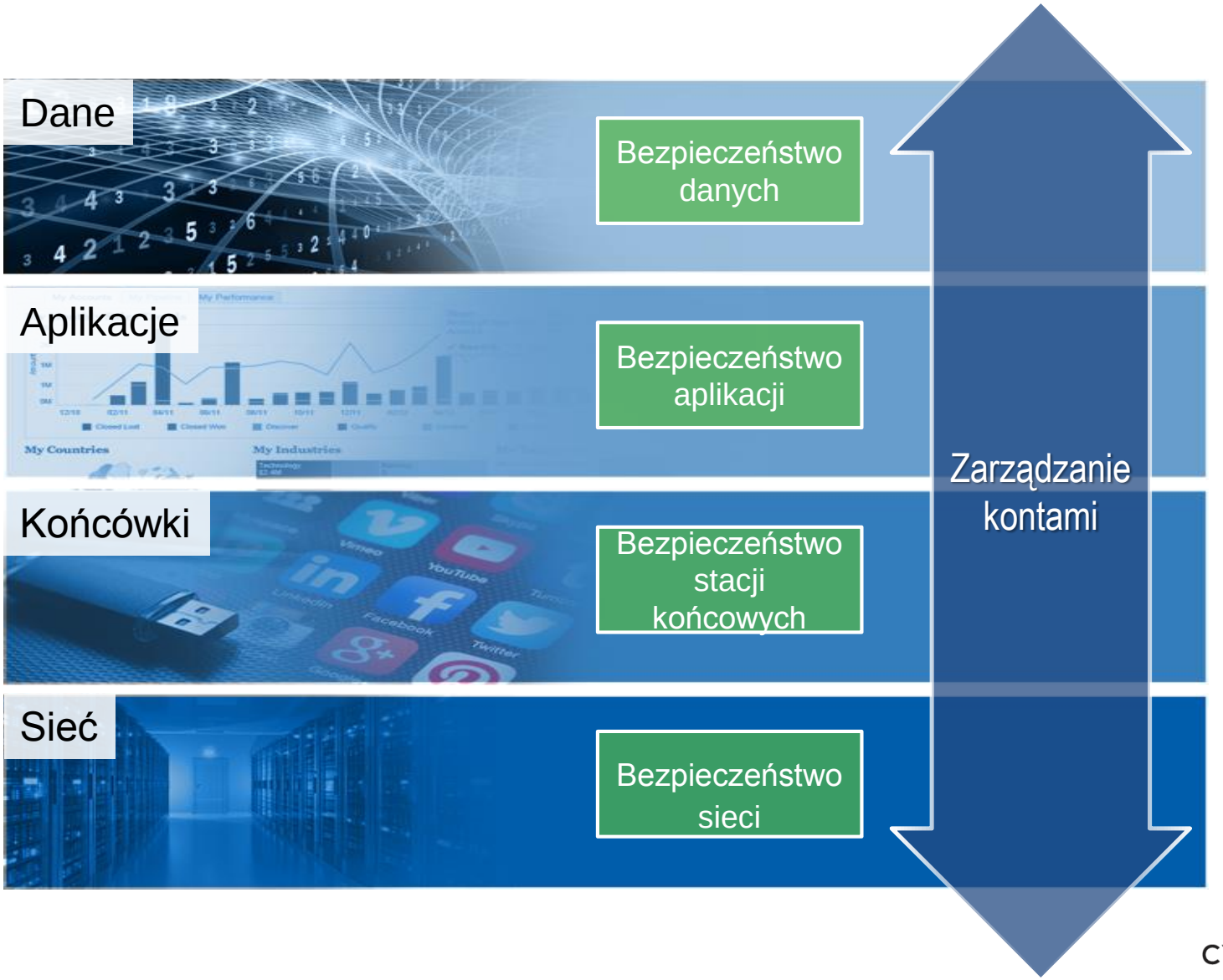




Architektura rozproszona CyberArk



Privilege Account Security



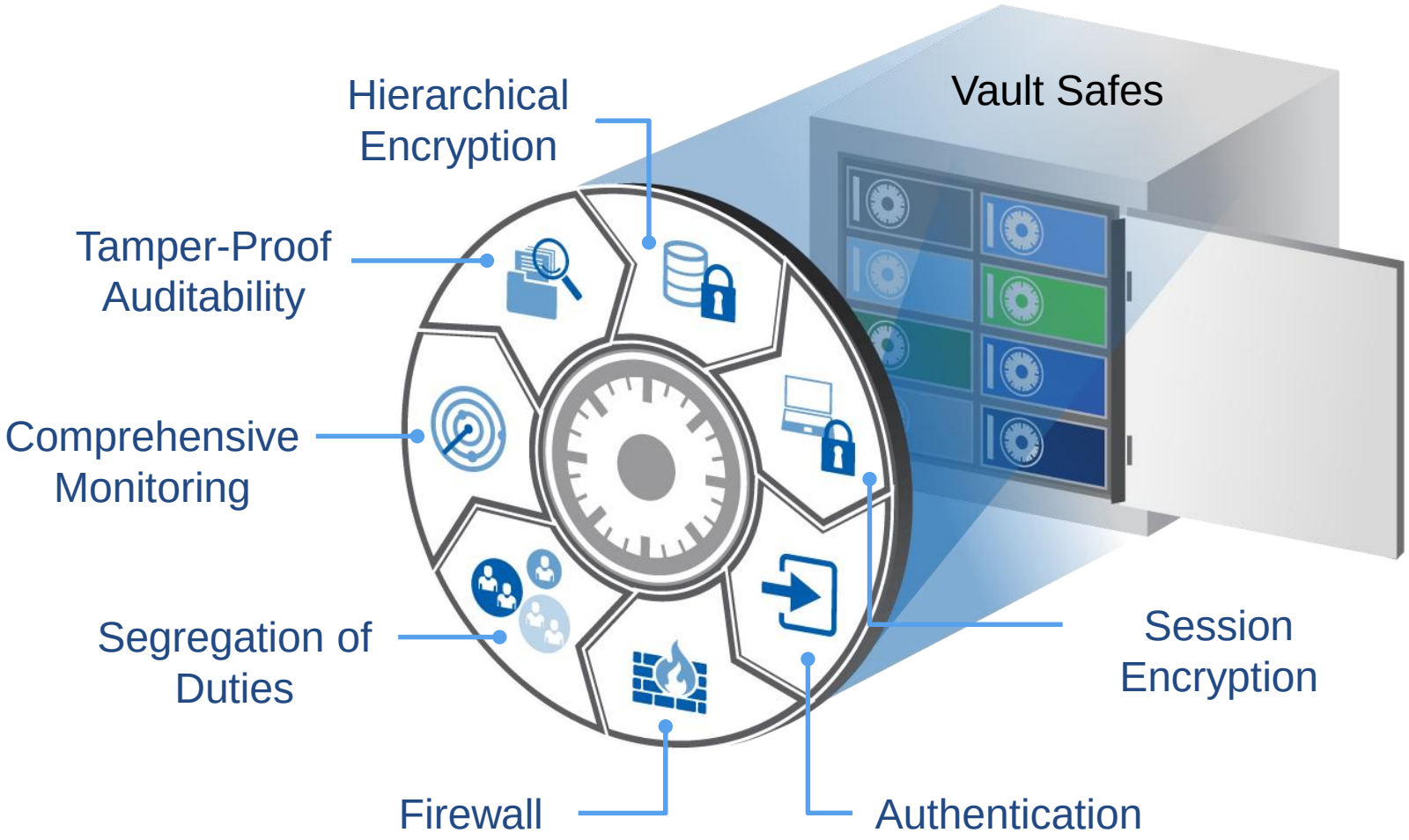
Kluczowe korzyści

- Zmniejszenie ilości zagrożeń związanych z zaawansowanymi atakami
- Osiągnięcie i utrzymanie zaleceń polityk bezpieczeństwa
- Redukcja kosztów związanych z obsługą helpdesk
- Podniesienie wydajności pracowników
- Zmniejszenie ryzyka operacyjnego
- BEZPIECZEŃSTWO!

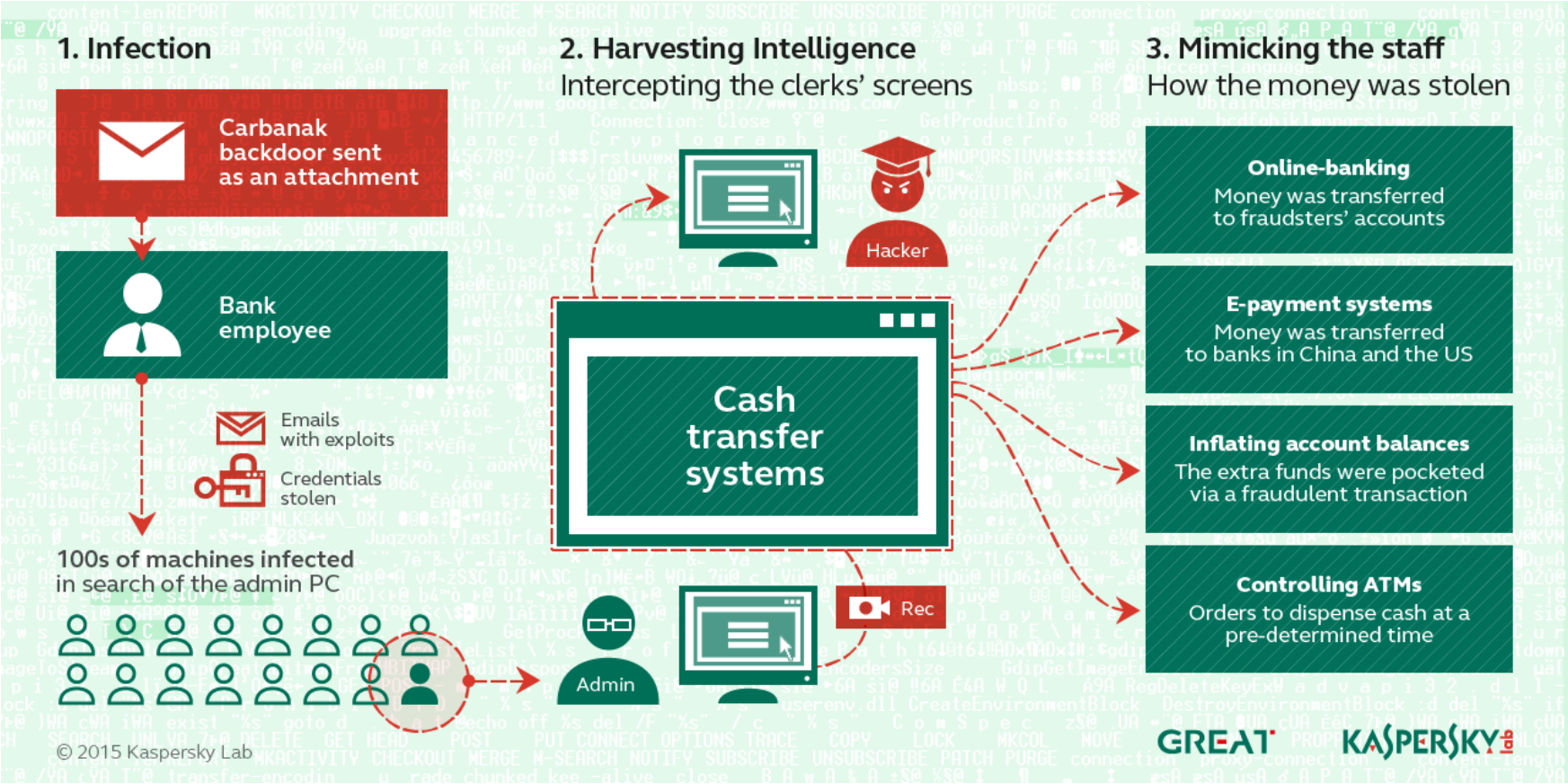
CYBERARK

Dziękujemy

Layers of Security in the Digital Vault



Kasperky's Analysis of the Carbanak Attack



http://www.scmagazineuk.com/2014-sc-awards-europe-winners/article/344676/1/

Best Advanced Persistent Threat (APT) Protection
Winner

CyberArk Privileged Account Security solution (v8), CyberArk,

Highly Commended

Lumension Endpoint Management and Security Suite, Lumension Security

Zscaler for APTs, Zscaler

Finalist

FireEye Security Platform, FireEye,

Lancope StealthWatch® System- Best APT Solution, Lancope,

Trend Micro Deep Discovery, Trend Micro,

Websense TRITON Enterprise, Websense,

2014 SC Awards Europe Winners

Raporty branżowe

Leadership Compass
Privilege Management
By KuppingerCole

„W tym Leadership Compass, CyberArk jest na pozycji lidera pod każdym względem. Wynika to przede wszystkim z najlepszego rozumienia potrzeb rynkowych, innowacyjnego podejścia do ich zaspokajania oraz ciągłego doskonalenia funkcjonalnego narzędzi które posiada w ofercie”.

By **Peter Cummings**
pc@kuppingercole.com
January 2014